

ĐỒ ÁN 2

Xây dựng Ứng dụng Web Serverless với Kiến trúc bảo mật & Tối ưu chi phí

I. Thông tin chung

Trường	Chi tiết
Mã đồ án	PROJECT2
Thời gian	Dự kiến 3 tuần
Nhóm	Nhóm 3 sinh viên
Hạn nộp	xem lịch Moodles

II. Mục tiêu

Đồ án này hướng đến các kết quả học tập sau của môn học: G2.1, G2.2, G2.3, G2.4, G3.1, G5.2, G5.3

- Thiết kế hệ thống điện toán đám mây sử dụng các dịch vụ serverless có quản lý
- Triển khai bảo mật theo nguyên tắc Least Privilege và cô lập mạng
- Cấu hình giám sát, cảnh báo và quản lý chi phí
- Xây dựng và triển khai ứng dụng web hoàn chỉnh trên nền tảng điện toán đám mây
- Giải thích kiến trúc hệ thống, luồng yêu cầu và cơ chế tự động mở rộng

III. Mô tả đồ án

Sinh viên sẽ thiết kế và triển khai ứng dụng web Quản lý Công việc sử dụng kiến trúc serverless hiện đại trên AWS. Hệ thống phải thể hiện khả năng tự mở rộng, bảo mật nhiều lớp và kết nối cơ sở dữ liệu hoàn toàn qua mạng riêng của AWS — không đi qua internet công cộng.

Mục tiêu cốt lõi

- 100% kiến trúc serverless — không được sử dụng máy ảo (EC2)
- Tự động mở rộng dựa trên lưu lượng thực tế
- High Availability (HA) theo thiết kế — không cần cấu hình failover thủ công
- Cô lập mạng: Lambda phải kết nối DynamoDB qua VPC Endpoint, không qua internet
- Bảo mật frontend: S3 bucket phải riêng tư, chỉ truy cập qua CloudFront + OAC
- Tuân thủ chặt chẽ giới hạn Free Tier / Không phát sinh chi phí
- Khả năng quan sát đầy đủ và kiểm soát chi phí

IV. Yêu cầu kỹ thuật

1. Thiết kế ứng dụng — Frontend

1.1 Công nghệ và tính năng

- Công nghệ: HTML, CSS, JavaScript (không bắt buộc dùng framework frontend)
- Các tính năng yêu cầu:
 - Các thao tác CRUD: tạo, xem, cập nhật, xóa công việc
 - Giao diện danh sách công việc responsive
 - Lọc công việc theo ngày hết hạn và mức ưu tiên

1.2 Lưu trữ Frontend — Yêu cầu bảo mật

 KHÔNG ĐƯỢC
S3 bucket KHÔNG được cấu hình ở chế độ public.
KHÔNG được bật Static Website Hosting trên S3.
Các file KHÔNG được truy cập qua URL S3 trực tiếp dạng: <code>https://bucket.s3.amazonaws.com/...</code>

 Yêu cầu
S3 bucket phải ĐƯỢC ĐẶT LÀ PRIVATE — tất cả bốn tùy chọn Block Public Access đều phải bật.
CloudFront phải là CDN duy nhất phục vụ frontend cho người dùng.
Origin Access Control (OAC) phải được cấu hình để CloudFront đọc được từ S3.
Bucket Policy của S3 chỉ cho phép CloudFront Service Principal đọc các đối tượng.

1.3 Bảng chứng bảo mật Frontend

Nhóm phải nộp đủ bốn mục liệt kê dưới đây. Thiếu bất kỳ mục nào sẽ bị trừ điểm trong hạng mục Bảo mật.

ID	Mục bằng chứng	Cách thu thập	Thể thức chấp nhận
SE-1	S3 Block Public Access bật	Chụp màn hình tab Permissions của S3 bucket cho thấy cả bốn checkbox được bật	Screenshot
SE-2	Truy cập trực tiếp S3 bị từ chối	Mở trình duyệt hoặc chạy curl tới <code>https://<bucket>.s3.amazonaws.com/index.html</code> và ghi lại phản hồi 403 Forbidden / AccessDenied	Screenshot hoặc curl output
SE-3	Truy cập CloudFront thành công	Mở URL CloudFront (<code>https://<id>.cloudfront.net</code>) và ghi lại trang web hoạt động với HTTP status 200	Screenshot
SE-4	OAC gắn vào CloudFront	Screenshot trang Settings của CloudFront distribution cho thấy rõ 'Origin access: Origin access control settings' và tên OAC	Screenshot

2. Backend API

2.1 Ngôn ngữ và các endpoint API

- Ngôn ngữ: Node.js 20.x hoặc Python 3.12
- Các endpoint yêu cầu:

Phương thức	Đường dẫn	Mô tả
GET	/tasks	Lấy toàn bộ danh sách công việc
POST	/tasks	Tạo công việc mới
PUT	/tasks/:id	Cập nhật công việc theo ID
DELETE	/tasks/:id	Xóa công việc theo ID

2.2 Kiến trúc Compute

- Serverless compute: AWS Lambda
- Hướng sự kiện: Lambda được kích hoạt bởi API Gateway
- Stateless: mỗi yêu cầu độc lập hoàn toàn; không lưu trạng thái bên trong Lambda
- Tự mở rộng: Lambda mở rộng tự động — không cần cấu hình thêm

Yêu cầu 4 Lambda Function cho 4 chức năng:

Lambda Function	Endpoint	HTTP Method	Chức năng
GetTasksFunction	/tasks	GET	Lấy danh sách công việc từ DynamoDB
CreateTaskFunction	/tasks	POST	Tạo công việc mới vào DynamoDB
UpdateTaskFunction	/tasks/:id	PUT	Cập nhật công việc theo ID trong DynamoDB
DeleteTaskFunction	/tasks/:id	DELETE	Xóa công việc theo ID khỏi DynamoDB

⚠ Mỗi Lambda Function phải được triển khai riêng biệt, có IAM Role riêng, và được gắn vào API Gateway tương ứng. Không được gộp nhiều chức năng vào một Lambda Function duy nhất.

3. Mạng — Kết nối Lambda tới DynamoDB

Giải thích kỹ thuật
Thách thức mạng cốt lõi: Lambda cần đọc/ghi DynamoDB. Có hai cách tiếp cận:
Cách 1 (SAI): Lambda gọi DynamoDB qua internet công cộng — yêu cầu NAT Gateway — tốn khoảng 32/tháng.

Cách 2 (ĐÚNG): Lambda gọi DynamoDB qua VPC Gateway Endpoint — traffic ở trên backbone riêng của AWS — tốn 0.

Đồ án này bắt buộc sử dụng Cách 2.

3.1 Cấu hình VPC yêu cầu

Sinh viên phải tạo Custom VPC và triển khai các Lambda function bên trong VPC đó:

Thành phần	Cấu hình	Mục đích
Custom VPC	CIDR: 10.0.0.0/16	Mạng ảo riêng để cô lập compute
Private Subnet AZ-1	Ví dụ: 10.0.1.0/24 tại ap-southeast-1a	Đặt Lambda functions vào subnet này
Private Subnet AZ-2	Ví dụ: 10.0.2.0/24 tại ap-southeast-1b	Đảm bảo High Availability trên hai AZ
VPC Gateway Endpoint	Tạo endpoint DynamoDB và liên kết với Route Table	Cho phép Lambda kết nối DynamoDB qua mạng riêng
Lambda Security Group	Outbound: cho phép port 443 tới DynamoDB Prefix List mà thôi	Ngăn Lambda truy cập internet công cộng
Route Table entry	Destination: pl-xxxxxx (DynamoDB Prefix List) -> vpce-xxxxxxx	Hướng traffic DynamoDB qua Endpoint

3.2 Gắn Lambda vào VPC — bước bắt buộc

Khi tạo mỗi Lambda function, phải cấu hình VpcConfig. Nếu không có trường này, Lambda chạy ngoài Custom VPC và sẽ không sử dụng Endpoint đã tạo.

🚫 **CẢM:** Việc tạo hoặc sử dụng NAT Gateway. NAT Gateway tính phí \$0.045/giờ = ~\$32/tháng dù không có traffic. Vi phạm quy tắc này sẽ bị điểm 0 cho cả Networking và Cost Efficiency. Giảng viên sẽ kiểm tra bằng cách xem VPC console — bất kỳ NAT Gateway nào tìm thấy = 0 điểm.

3.3 Bảng chứng Networking

ID	Mục bằng chứng	Cách thu thập	Thế thức chấp nhận
NE-1	VPC Endpoint tạo cho DynamoDB	Screenshot VPC > Endpoints cho thấy Service Name: com.amazonaws.<region>.dynamodb và Status: Available	Screenshot
NE-2	Lambda có VpcConfig	Screenshot tab Configuration > VPC của Lambda function cho thấy Subnets và Security Group được gắn	Screenshot
NE-3	Route table có Endpoint route	Screenshot Route Table của Private Subnet cho thấy dòng: Destination = pl-xxxxxx (DynamoDB Prefix List), Target = vpce-xxxxxxx	Screenshot

NE-4	Không có NAT Gateway	Screenshot VPC > NAT Gateways — danh sách phải trống hoặc tất cả entries đều có Status: Deleted	Screenshot
NE-5	Lambda gọi DynamoDB thành công	CloudWatch log của Lambda invocation cho thấy StatusCode 200 trên DynamoDB call, không có lỗi NetworkingError hoặc UnauthorizedAccess	Screenshot log

4. Cơ sở dữ liệu — Amazon DynamoDB

- Loại: NoSQL — Amazon DynamoDB
- High Availability tích hợp sẵn (sao chép multi-AZ, không cần cấu hình thêm)
- Hạn mức Free Tier: 25 GB lưu trữ, 25 RCU / 25 WCU mỗi tháng (không hết hạn)
- Yêu cầu cơ sở dữ liệu phải có ít nhất 2 users được khởi tạo sẵn để demo và kiểm thử (có thể thấy trong bảng DynamoDB khi kiểm tra)**

4.1 Schema bảng

Thuộc tính	Kiểu	Vai trò	Mô tả
taskId	String	Partition Key	UUID do Lambda tạo khi tạo công việc
userId	String	GSI partition key	ID của người dùng sở hữu công việc
title	String	Thuộc tính	Tiêu đề công việc
description	String	Thuộc tính	Chi tiết công việc (tùy chọn)
priority	String	Thuộc tính	Giá trị: low / medium / high
dueDate	String	Thuộc tính	Định dạng ISO: 2025-06-15
status	String	Thuộc tính	Giá trị: pending / done
createdAt	String	Thuộc tính	Timestamp ISO đặt lúc tạo

4.2 Global Secondary Index (GSI)

Tạo GSI để cho phép truy vấn hiệu quả tất cả công việc của một user:

- Tên GSI: userId-index
- GSI partition key: userId
- Projection: ALL

Không có GSI này, việc lấy công việc của user yêu cầu Scan toàn bộ bảng — không hiệu quả và không đáp ứng yêu cầu thiết kế của kiến trúc.

5. Bảo mật — IAM Least Privilege

5.1 Yêu cầu quyền

Mỗi Lambda function phải có IAM Role riêng. Không được dùng chung một role cho nhiều Lambda function.

IAM Role	Lambda	Hành động được phép (Allow)	Nghị cấm
----------	--------	-----------------------------	----------

LambdaTaskRole	Task Service	dynamodb:GetItem, PutItem, UpdateItem, DeleteItem, Query, Scan chỉ trên ARN của TasksTable; logs:CreateLogGroup, CreateLogStream, PutLogEvents; ec2:CreateNetworkInterface, DescribeNetworkInterfaces, DeleteNetworkInterface (yêu cầu khi gắn VPC)	Wildcard (*) cho action hoặc resource; truy cập bất kỳ bảng nào khác ngoài TasksTable
LambdaBaseRole	Các Lambda khác	logs:CreateLogGroup, CreateLogStream, PutLogEvents; ec2:CreateNetworkInterface, DescribeNetworkInterfaces, DeleteNetworkInterface	Bất kỳ quyền truy cập DynamoDB

5.2 Bảng chứng IAM

ID	Mục bằng chứng	Cách thu thập
IM-1	Hai IAM Role riêng biệt	Screenshot IAM > Roles được lọc theo tên dự án, hiển thị hai role riêng biệt
IM-2	Policy chỉ rõ ARN resource cụ thể	Mở Inline Policy hoặc JSON của mỗi Role và chụp trường 'Resource' — phải hiển thị ARN bảng DynamoDB cụ thể, không phải '*'
IM-3	Lambda gắn với Role đúng	Screenshot tab Configuration > Permissions của mỗi Lambda function cho thấy tên Role đúng

5b. Bảo mật truy cập Web App — Amazon Cognito

Ứng dụng web phải sử dụng Amazon Cognito để xác thực người dùng và bảo vệ truy cập vào các API.

5b.1 Yêu cầu Cognito

- Tạo Cognito User Pool để quản lý tài khoản người dùng
- Tạo Cognito App Client để frontend có thể xác thực
- Tích hợp Cognito Authorizer vào API Gateway: mọi request đến các endpoint /tasks đều phải đính kèm JWT token hợp lệ
- Frontend phải có giao diện đăng nhập (Login) và đăng ký (Sign Up) sử dụng Cognito
- Sau khi đăng nhập, frontend lưu JWT token và gửi kèm vào mọi lời gọi API
- Người dùng chưa đăng nhập sẽ nhận được phản hồi 401 Unauthorized khi truy cập API

5b.2 Bảng chứng Cognito — bắt buộc nộp

ID	Mục bằng chứng	Cách thu thập	Thẻ thức
CO-1	Cognito User Pool đã tạo	Screenshot trang Cognito > User Pools cho thấy tên Pool và Pool ID	Screenshot
CO-2	API Gateway Authorizer được cấu hình	Screenshot API Gateway > Authorizers cho thấy Cognito Authorizer liên kết với User Pool	Screenshot

CO-3	Truy cập API không có token bị từ chối	Chạy curl gọi API không kèm Authorization header — phải nhận phản hồi 401 Unauthorized	Screenshot/curl
CO-4	Truy cập API với token hợp lệ thành công	Chạy curl gọi API kèm JWT token hợp lệ — phải nhận phản hồi 200 OK với dữ liệu	Screenshot/curl

6. API Gateway — Định tuyến và Bảo mật

6.1 Cấu hình yêu cầu

- Loại API: REST API (không sử dụng HTTP API cho dự án này)
- Deployment stage: prod
- HTTPS: bật theo mặc định — API Gateway tự động cấp SSL certificate

6.2 Giới hạn tốc độ (throttling)

Tham số	Giá trị khởi đề nghị	Lý do
Rate (req/s)	100	Giới hạn thông lượng yêu cầu mỗi người dùng
Burst	50	Số yêu cầu đồng thời tối đa được phép
Lambda Reserved Concurrency	Tìm hiểu giá trị reserved concurrency có thể thiết lập	Sinh viên cần tìm hiểu và giải thích: (1) Reserved Concurrency là gì? (2) Giá trị nào phù hợp cho môi trường Free Tier? (3) Ảnh hưởng của việc đặt quá thấp hoặc quá cao? Ghi rõ giá trị đã chọn và lý do trong báo cáo.

6.3 CORS — yêu cầu bảo mật

- Access-Control-Allow-Origin: phải được đặt thành CloudFront domain của bạn mà thôi
- Ví dụ: https://d1abc123.cloudfront.net
- Việc đặt "*" không được phép và sẽ bị trùng điểm

7. Giám sát và Quản lý Chi phí

7.1 CloudWatch Dashboard

Tạo CloudWatch Dashboard tên TaskManager-Dashboard với ít nhất năm widget sau:

Widget	Metric	Namespace	Mục đích
Invocations	Invocations	AWS/Lambda	Tổng số request
Duration	Duration (P50, P99)	AWS/Lambda	Thời gian thực thi Lambda
Errors	Errors	AWS/Lambda	Lỗi mức function
Throttles	Throttles	AWS/Lambda	Request bị giới hạn bởi concurrency cap
API Latency	Latency	AWS/ApiGateway	Thời gian phản hồi toàn trình
4xx / 5xx	4XXError, 5XXError	AWS/ApiGateway	Tỷ lệ lỗi client và server

7.2 CloudWatch Alarms — bắt buộc

Tên Alarm	Điều kiện	Hành động
Lambda-Error-Alarm	Lambda Errors > 10 trong 5 phút	Gửi email qua SNS
API-5xx-Alarm	API Gateway 5XXError > 5 trong 5 phút	Gửi email qua SNS

7.3 Bảng chứng Log

Log	Nội dung yêu cầu	Vị trí log group
Request thành công	Log hiển thị dòng REPORT với StatusCode 200, Duration, Billed Duration và Memory Used	/aws/lambda/<function-name>
Request lỗi	Log hiển thị lỗi ERROR hoặc stack trace do gửi input không hợp lệ (ví dụ thiếu trường bắt buộc)	/aws/lambda/<function-name>

7.4 Kiểm soát chi phí

- Tạo AWS Budget với giới hạn 0.01 mỗi tháng
- Cấu hình cảnh báo tại 80% (0.008) và 100% (0.01) — cả hai đều phải gửi thông báo email
- Tìm hiểu và thiết lập Lambda Reserved Concurrency phù hợp (ghi rõ giá trị đã chọn và lý do trong báo cáo)
- Áp dụng API Gateway throttling theo mục 6.2

V. Sản phẩm nộp

1. Ứng dụng Web

- Frontend truy cập được qua URL CloudFront
- Backend API trả về phản hồi JSON chính xác
- Tất cả bốn endpoint CRUD hoạt động đúng
- Tích hợp cơ sở dữ liệu được xác minh — dữ liệu tồn tại trong DynamoDB giữa các request
- Chức năng xác thực người dùng qua Cognito hoạt động đúng (Login / Sign Up)

2. Sơ đồ Kiến trúc

Sơ đồ vẽ bằng bất kỳ công cụ nào (draw.io, Lucidchart, vẽ tay, ...) phải hiển thị rõ tất cả các thành phần sau. Sơ đồ được chấm theo mức độ đầy đủ — thiếu bất kỳ mục nào sẽ bị trừ điểm.

Tầng	Thành phần yêu cầu
Edge	CloudFront + OAC + S3 riêng tư
API	API Gateway → kích hoạt Lambda

Compute (VPC)	Lambda có VpcConfig bên trong Private Subnets (4 functions riêng biệt)
Network	VPC Gateway Endpoint cho DynamoDB
Database	DynamoDB (với ít nhất 2 users)
Bảo mật	IAM — các Role riêng biệt; Cognito User Pool + Authorizer
Giám sát	CloudWatch + SNS alarms
Chi phí	AWS Budgets

3. Bảng chứng Bảo mật

Nộp tất cả các mục bằng chứng liệt kê dưới đây. Các file có thể tổng hợp dưới dạng PDF hoặc thư mục chứa file PNG/JPG:

ID	Mục bằng chứng	Hạng mục Rubric
SE-1	S3 Block Public Access — bốn tùy chọn đều bật	Triển khai Đám mây
SE-2	Truy cập trực tiếp S3 trả về 403 Forbidden	Triển khai Đám mây
SE-3	Truy cập CloudFront trả về 200 OK	Triển khai Đám mây
SE-4	OAC gắn vào CloudFront distribution	Triển khai Đám mây
CO-1	Cognito User Pool đã tạo	Triển khai Đám mây / Bảo mật
CO-2	API Gateway Cognito Authorizer được cấu hình	Triển khai Đám mây / Bảo mật
CO-3	Truy cập API không có token trả về 401 Unauthorized	Triển khai Đám mây / Bảo mật
CO-4	Truy cập API với token hợp lệ thành công	Triển khai Đám mây / Bảo mật
NE-1	VPC Endpoint cho DynamoDB — Status: Available	Hiểu biết Kiến trúc
NE-2	Lambda VpcConfig — Subnets và Security Group gắn	Hiểu biết Kiến trúc
NE-3	Route Table — dòng pl-xxx -> vpce-xxx hiện diện	Hiểu biết Kiến trúc
NE-4	Không có NAT Gateway (danh sách trống hoặc toàn bộ Deleted)	Hiệu quả Chi phí
NE-5	CloudWatch log: Lambda gọi DynamoDB thành công	Giám sát
IM-1	Hai IAM Roles riêng biệt với tên phân biệt	Triển khai Đám mây
IM-2	Policy JSON với ARN bảng DynamoDB cụ thể làm Resource	Triển khai Đám mây
IM-3	Mỗi Lambda gắn với Role đúng	Triển khai Đám mây

4. Monitoring Dashboard

- Screenshot CloudWatch Dashboard cho thấy ít nhất 5 widget với dữ liệu thực
- Screenshot 2 alarm đã tạo (trạng thái OK hoặc ALARM đều được chấp nhận)
- Screenshot trang cấu hình AWS Budget

5. Báo cáo Chi phí

- Screenshot AWS Cost Explorer hoặc Billing Dashboard
- Chứng minh tổng chi phí ≤ 0.01 trong suốt thời gian dự án
- Nếu có phát sinh chi phí, giải thích lý do và mô tả biện pháp khắc phục

6. Tài liệu

Báo cáo kỹ thuật phải giải thích rõ bốn khái niệm sau. Giảng viên sẽ hỏi trực tiếp trong buổi bảo vệ:

Khái niệm	Nội dung phải giải thích	Tỷ trọng gần đúng
Luồng request	Mô tả từng bước từ khi người dùng nhấn 'Tạo công việc' đến khi nhận phản hồi: Trình duyệt → CloudFront (tài sản tĩnh) hoặc API GW → Lambda → VPC Endpoint → DynamoDB → phản hồi	~8%
Tự mở rộng Serverless	Giải thích Lambda mở rộng từ 0 đến N instance đồng thời. Mô tả API Gateway hoạt động như load balancer tự nhiên. Giải thích tại sao không cần ALB.	~6%
CDN và OAC	Giải thích CloudFront caching hoạt động thế nào (cache HIT vs MISS). Định nghĩa OAC và lý do cần thiết. Giải thích tại sao S3 phải riêng tư.	~4%
VPC Endpoint	Giải thích tại sao Lambda bên trong Private Subnet cần VPC Endpoint để kết nối DynamoDB. Mô tả đường đi của traffic (AWS private backbone). So sánh với NAT Gateway về chi phí và bảo mật.	~4%

7. Source Code

- Frontend: HTML, CSS, JavaScript
- Backend: Node.js hoặc Python — đủ bốn CRUD handler tương ứng với bốn Lambda function riêng biệt
- (Tùy chọn) CloudFormation hoặc AWS SAM template — nếu có sử dụng IaC, bắt buộc nộp kèm source code IaC
- README mô tả cách chạy local và cách deploy lên AWS

VI. Tiêu chí Đánh giá (Rubric)

Hạng mục	Tỷ trọng	Yêu cầu để được điểm tối đa
----------	----------	-----------------------------

Chức năng	20%	Tất cả bốn thao tác CRUD hoạt động đúng. Frontend, backend và DynamoDB tích hợp chính xác. Bộ lọc theo độ ưu tiên và ngày hết hạn hoạt động.
Triển khai Đám mây	25%	S3 private + CloudFront OAC xác minh (SE-1 → SE-4). Lambda trong VPC có Endpoint (NE-1 → NE-3). IAM Least Privilege với role riêng (IM-1 → IM-3). Cognito xác thực đúng (CO-1 → CO-4). API Gateway CORS chỉ cho phép CloudFront domain.
Hiểu biết Kiến trúc	20%	Sinh viên giải thích được toàn bộ luồng request. Hiểu VPC Endpoint và lý do thay thế NAT Gateway. Hiểu Lambda auto-scaling và vai trò load balancing của API Gateway. Hiểu CloudFront CDN caching và OAC.
Giám sát	10%	CloudWatch Dashboard với 5+ widget có dữ liệu thực. Hai alarm được tạo và cấu hình. Screenshot log thành công và log lỗi đã nộp (NE-5). Cấu hình thông báo email SNS.
Hiệu quả Chi phí	15%	Không có NAT Gateway (NE-4). Lambda concurrency được giới hạn phù hợp (ghi rõ giá trị và lý do). AWS Budget 0.01 được cấu hình. Tổng chi phí dự án = 0 hoặc gần 0.
Tài liệu	10%	Báo cáo giải thích rõ cả bốn khái niệm. Sơ đồ kiến trúc đủ các thành phần yêu cầu. Đủ 16 mục bằng chứng (SE/NE/IM/CO). Nếu có dùng công cụ GenAI, phải cung cấp lịch sử prompt đã sử dụng (xuất file hoặc screenshot chat). Nếu dùng IaC, nộp kèm source code IaC.

TỔNG: 100%. Thiếu bất kỳ mục bằng chứng bắt buộc sẽ bị trừ điểm trong hạng mục rubric tương ứng, dù hệ thống hoạt động đúng chức năng.

VII. Tiến độ Đồ án

Tuần	Công việc chính	Kết quả dự kiến cuối tuần
Tuần 1	Phát triển frontend và backend cục bộ	Frontend chạy được cục bộ. Cả bốn Lambda CRUD handler được viết và kiểm thử cục bộ với DynamoDB Local hoặc thư viện mock.
Tuần 2	Deploy hạ tầng đám mây và kết nối cơ sở dữ liệu	Custom VPC + 2 Private Subnets + VPC Endpoint tạo xong. Lambda deploy trong VPC. DynamoDB table và GSI tạo xong. API Gateway cấu hình CORS và throttling. CloudFront + OAC + S3 private sẵn sàng. Cognito User Pool và Authorizer cấu hình xong. Thu thập đủ bằng chứng NE-1 → NE-5.
Tuần 3	Kiểm thử, thiết lập giám sát, tài liệu và nộp bài	CloudWatch Dashboard + 2 Alarms + 2 log screenshot hoàn tất. AWS Budget cấu hình. Báo cáo chi phí sẵn sàng. Tài liệu được viết đầy đủ. Đủ 16 mục bằng chứng (SE/NE/IM/CO) được tổng hợp và nộp.

VIII. Lưu ý quan trọng

Các lỗi thường gặp cần tránh

Lỗi	Mô tả	Hậu quả
S3 public	Đặt bucket ở chế độ public hoặc bật Static Website Hosting	Mất toàn bộ điểm SE-1 → SE-4 (Triển khai)
Dùng NAT Gateway	Tạo NAT Gateway để Lambda trong VPC kết nối internet	Mất toàn bộ điểm NE-4 và Hiệu quả Chi phí. Phát sinh ~32/tháng.
Lambda ngoài VPC	Tạo Lambda mà không cấu hình VpcConfig	Mất toàn bộ điểm NE-1 → NE-3 dù VPC Endpoint đã tạo đúng
IAM Role chung	Dùng một Role cho nhiều Lambda, hoặc dùng quyền wildcard	Mất toàn bộ điểm IM-1 → IM-3
CORS wildcard	Đặt Access-Control-Allow-Origin: * thay vì CloudFront domain cụ thể	Trùng điểm Triển khai (Bảo mật)
Thiếu bằng chứng	Không chụp screenshot theo bảng SE/NE/IM/CO	Trùng điểm theo từng mục, dù hệ thống hoạt động đúng
Không nộp prompt GenAI	Dùng GenAI hỗ trợ nhưng không cung cấp lịch sử prompt	Trùng điểm phần Tài liệu

Danh sách kiểm tra trước khi nộp

- S3 bucket: bốn tùy chọn Block Public Access = BẬT (SE-1)
- Kiểm tra truy cập URL S3 trực tiếp — phải trả về 403 Forbidden (SE-2)
- Kiểm tra URL CloudFront — phải trả về 200 OK (SE-3)
- CloudFront distribution: Origin access = OAC (SE-4)
- VPC > Endpoints: DynamoDB endpoint có mặt, Status = Available (NE-1)
- Lambda > Configuration > VPC: Subnets và Security Group hiển thị (NE-2)
- Private Subnet Route Table: dòng pl-xxx -> vpce-xxx có mặt (NE-3)
- VPC > NAT Gateways: danh sách trống hoặc toàn bộ Deleted (NE-4)
- CloudWatch log: Lambda gọi DynamoDB thành công, không có NetworkError (NE-5)
- IAM: 2 Role riêng biệt, mỗi Policy dùng ARN bảng cụ thể không phải '*' (IM-1, IM-2, IM-3)
- Cognito User Pool tạo xong, Authorizer cấu hình trên API Gateway (CO-1, CO-2)
- API không có token trả về 401, có token hợp lệ trả về 200 (CO-3, CO-4)
- Cơ sở dữ liệu có ít nhất 2 users khởi tạo sẵn
- CloudWatch Dashboard: 5+ widget hiển thị dữ liệu thực
- 2 CloudWatch Alarms đã tạo và hiển thị
- AWS Budget 0.01 cấu hình và email subscription xác nhận
- Screenshot log thành công + log lỗi từ CloudWatch
- Tài liệu đủ bốn khái niệm: luồng request, scaling, CDN, VPC Endpoint
- Sơ đồ kiến trúc thể hiện rõ Lambda VpcConfig trong VPC boundary và Cognito
- Sơ đồ kiến trúc bao gồm IAM roles, CloudWatch, SNS, AWS Budgets, Cognito
- Nếu có sử dụng GenAI: nộp kèm lịch sử prompt (xuất file chat hoặc screenshot)
- Nếu có dùng IaC (CloudFormation/SAM): nộp kèm source code IaC

- Link video demo cho trường hợp bảo vệ dự phòng